Monthly Intelligence Dispatch

September 2020

The Group-IB Monthly Threat Intelligence Dispatch (Group-IB MTID) is a monthly newsletter by Group-IB, an international company that specializes in preventing cyberattacks and developing information security products. The dispatch aims to provide information about the latest cyberthreats, criminal groups' attacks, data leaks, and malware. The document contains news about arrests, legal action against hacking groups, short-term forecasts, and recommendations to help take timely measures to reduce security risks and ensure protection against cyberthreats. Group-IB MTID is intended for internal use only and its distribution is not permitted.

Key findings

- Group-IB released an analytical report on OldGremlin, a new threat group that attacks banks, industrial enterprises, healthcare organizations, and software developers.
- A new attack by the Chinese APT group Winnti was detected, with several dozen computers infected worldwide, including Russia, the United States, Japan, and South Korea.
- Group-IB detected malicious mailouts purporting to be by **the rector of the Lomonosov Moscow State University**. The emails contained a password stealing program.
- Germany is searching for DoppelPaymer ransomware operators, whose attack on a hospital resulted in the death of a patient.
- **Visa** discovered a new JS sniffer called Baka, which is injected into the code of online shops and used for stealing the payment card details of users who make online purchases.
- September saw a spike in the number of instances of bank card compromise affecting Latin American banks.
- FinCERT of Russia's Central Bank warned about a new scheme that enabled threat actors to obtain additional information about the customers of one bank and subsequently use it for fraud purposes applying social engineering techniques.
- **Yevgeniy Nikulin**, a Russian citizen, was sentenced to seven years in prison in the United States.

OldGremlin

Group-IB discovered a new threat group called OldGremlin. Since spring, OldGremlin has carried out at least nine malicious email campaigns. Despite cybercriminals' unspoken agreement to "not work on .RU," OldGremlin, which is made up of Russian-speaking hackers, actively attacks exclusively Russian companies: banks, industrial enterprises, healthcare organizations, and software developers. The group uses custom backdoors **TinyNode** or **TinyPosh**, waits for some time and then encrypts a target corporate network using another custom tool called **TinyCryptor**. The "gremlins" also use **Cobalt Strike**, a penetration testing tool popular among APT groups and cybercriminals.

Similar to threat groups that "work" on overseas targets, OldGremlin can be put in the **big-game hunting** category, which includes ransomware operators that are after large targets — corporate networks.

OldGremlin carries out multistage targeted attacks on Russian companies and banks using sophisticated tactics and techniques similar to those employed by APT groups; e.g., instead of sending out their TinyCryptor ransomware straightforwardly (i.e., in emails), the threat actors first gain remote access to a victim machine and use it as a foothold to then conduct reconnaissance, collect data, and move laterally across the organization's network. If the machine (of a random victim) is not in the corporate network's domain, it is encrypted straight away.

OldGremlin threat actors closely follow the news: the topics of their mailouts can be remote working practices during the pandemic, invitations for an interview by a financial journalist at a major publication, or protests in Belarus.

Winnti

Experts at **Positive Technologies** discovered a new attack by the Chinese state-sponsored threat group **Winnti** (also known as Suckfly, APT41, Wicked Panda, and Barium). Several dozen computers have been infected in countries around the world, including Russia, the United States, Japan, and South Korea. The analysts identified some of the attacked organizations, which included five Russian and German developers of software for financial organizations. In their report, the experts say that in a number of cases the hackers carried out supply chain attacks. The victims are specialized software manufacturers that provide their solutions to a big number of companies and are very likely to be used as a foothold for developing attacks. Winnti attacks countries around the world: Russia, the United States, Japan, South Korea, Germany, Mongolia, Belarus, India, and Brazil. The affected sectors include the gaming, software development, aerospace, energy, pharmaceutical, financial, telecommunications, and other industries.

Loki PWS

From September 9 to September 16, **Group-IB** detected a fake mailout purporting to be by the rector of the Lomonosov Moscow State University Victor Sadovnichy. The emails contained Loki PWS, a program for stealing passwords. The recipients were financial, industrial, and government organizations in Russia. By posing as Victor Sadovnichy, the threat actors asked the recipients to view a document attached to the email (a description of the 2020 budget) and promptly send their commercial proposals. The threat actors were too lazy to change or check all the links in the template, which indicates that there may be other attacks against overseas universities. The sender of the fake emails is admin@msu.ru or admin@rector.msu.ru. In reality, however, the emails were sent out from a compromised mail server of Hotel Afonso V, a Portuguese hotel located in the city of Aveiro. All of the emails contained a .zip archive called Запрос коммерческого предложения [Request for commercial proposal] with an .exe file within. Launching it installed a program from the Loki PWS family intended for stealing logins and passwords from infected computers.

DoppelPaymer

Germany's Ministry of Justice is investigating a ransomware attack against a local hospital, which resulted in the death of a patient. For Russia, this incident may come as an unpleasant surprise: last week, the German Ministry of Justice published a report, in which it says that the attack involved DoppelPaymer ransomware and that a "hacker group from Russia" may be behind it. The DoppelPaymer ransomware was discovered in April 2019. As with its predecessor BitPaymer, the ransomware was at first distributed using the notorious Dridex Trojan, which is associated with the Evil Corp threat group of Russian origin. Later, however, the DoppelPaymer operators started also using other methods of gaining initial access, such as vulnerabilities in publicly available applications. This could indicate that this program may be used by multiple threat groups.

UHS

Universal Health Services (UHS), a Fortune 500 company that manages about 400 healthcare facilities in the US, the UK, and Puerto Rico, fell victim to ransomware. The attack took place in the night between Saturday and Sunday. The employees say that at the time, their computers started restarting and then the infected machines showed a message with a ransom demand. In the end, the IT personnel of the healthcare facilities asked the staff to shut down their computers in order to prevent the threat from spreading further. Some patients were denied help, others were referred to other clinics, since UHS facilities were unable to perform lab tests.

Ragnar Locker

The French container transportation and shipping company CMA CGM fell victim to a ransomware attack, most likely involving Ragnar Locker. The attack affected the company's Chinese branches in Shanghai, Shenzhen, and Guangzhou. CMA CGM is one of the largest logistics companies in the world with 755 offices, 750 warehouses, and more than 110,000 employees in 160 countries. The official announcement states that the attack affected a number of the company's peripheral servers, forcing IT staff to disable external access to applications to prevent further spread of the threat.

LATAM

September saw a rise in the number of instances of bank card compromise affecting Latin American banks. On September 1, 2020, the card shops Bestvalid and Findsome published a database called 01 Sep usmixgood; simultaneously, the same cards were published on Entershop as part of the 09 ALFA ROMEO database. The overall number of cards in this database is 7,239. Similarly, on September 3, 2020, a database called 03 Sep usmixgood was posted (09 AUDI for Entershop). The overall number of cards in this database is 10,941. All the cards were published in CC format, which is textual bank card information that includes full card numbers, expiration dates, and CVV/CVC codes.

Group-IB's monitoring of card shops revealed a database called SPORTPRACTISE-DISCOUNT-SALE, which appeared on Joker's Stash and contained 190,000 cards, with 18,034 of them belonging to Mexican banks. The same resource later published a database called MAXIMALIST-DISCOUNT-SALE containing 260,000 cards, 25,460 of which belonged to Mexican banks. The cards were published in CC format. Some 40,000 cards from the two databases belong to Mexican banks, which is highly unusual for the region.

Saudi Arabia

On September 4, Group-IB specialists discovered a database with 16,000 cards, which was posted on Findsome, Bestvalid, and Entershop at once. The cards were published in CC format and belonged to banks in West Asia: 85% of them belonged to Saudi Arabia and 11% — to Qatar. The total price of the databases ranges between $288,00 and $306,000 depending on the card shop. Interestingly, despite the different names, the card data in the databases is the same. Their simultaneous publication may suggest that the resources Findsome, Bestvalid, and Entershop are part of a unified system for selling compromised cards.

Baka

Visa reported about a new sniffer called Baka, which is injected into the code of online shops and used for stealing the bank card data of users who make online purchases. Baka is almost impossible to capture: it is automatically deleted from webpages after transactions are carried out. The sniffer loads dynamically to avoid static malware scanners and uses unique encryption parameters for each victim to obfuscate the malicious code. Baka attacks were detected in several online shops in various countries. The virus loads on checkout pages using a special script and then automatically removes itself.

Fraud

FinCERT of Russia's Central Bank warned financial organizations about a new scheme that enabled threat actors to obtain additional information about the customers of one bank and subsequently use it for fraud purposes applying social engineering techniques. The threat actors called an interactive voice response (IVR) system faking customer phone numbers and requested data on the customers' account balances by entering the last four digits of card numbers. The fraudsters then used social engineering techniques; they called their victims posing as the employees of a financial organization. According to FinCERT, the customers phone and bank card numbers had been compromised and distributed online. The source of this data has not been identified.

SIM swapping

Threat actors attacked banking customers using social engineering, SIM swapping, and remote access software. A total of three victims lost over $350,000. All of the cases involved identical methods. The scheme started with a fake sale of an apartment at a low price. The fraudsters explained the tempting offer by their urgent need for money. In order for the victims to believe this information, the attackers offered to show additional photographs and videos of the living space. To transfer media files, the users were persuaded to install AnyDesk, a remote access application. The criminals kept access to the users' computers even after the files were transferred. Their main goal was to steal credentials from bank accounts, but the fraudsters often faced a serious barrier in the form of two-factor authentication (2FA). This is where the SIM swapping technique came in handy, with the help of which the attackers could receive text messages and calls intended for their victims.

Attacks against small and medium-sized businesses

Threat actors have been using a new scheme in their attacks against small and medium-sized companies. They disguise their actions as “operating expense payments.” First, the victim receives an email, in which the senders claim that they transferred several thousand dollars and say that all the details are available at a link to a legitimate data storage service included in the email. Using a well-known data storage service enabled the fraudsters to bypass security solutions. The unsuspecting recipient usually follows the link and sees information about compensation as an “operating expense payment.” If the victim clicks on the form, they will be redirected to a fraudulent resource and asked to create an account and a password for it as well as to enter their first and last names. Finally, the user will be asked to complete identification, which requires a payment of $5 as a commission. This sum goes to the threat actors.

ATM	Malware for ATMs and POS terminals was put up for sale on a hacker forum. According to the description, the malware targets ATMs manufactured by NCR, Wincor, and Diebold Nixdorf. The author asks $10,000 for the source code.
Windows XP	The source code of Windows XP SP1 and other versions of the operating system were allegedly leaked online. Some 43 GB worth of data was published on 4chan. Though these systems are no longer supported, many of their components or solutions that are based on them still appear in Microsoft's operating systems today. The source codes significantly simplify the process of searching for vulnerabilities both in Windows XP and, potentially, Windows 10.
WordPress	Millions of WordPress-powered websites were attacked by threat actors. The flurry of hacking activity was caused by the discovery of a zero-day vulnerability in File Manager, a popular WordPress plugin used on over 700,000 websites. The vulnerability allowed unauthenticated users to upload arbitrary files on target websites. The news was reported by Defiant. The threat actors identified WordPress-based websites and tried to upload web shells disguised inside image files on their victims' servers to gain remote access to the systems. If access was gained, the hackers ensnared the victim websites inside a botnet. Defiant reported that they blocked attacks against 1.7 million websites, which is more than half of the number of WordPress sites using the Wordfence web firewall.

Arrests and sentences

Nikulin

Yevgeniy Nikulin, a Russian citizen who had been facing cybercriminal charges for several years, was sentenced to 88 months (seven years and four months) in prison. The sentence was announced in federal court in San Francisco, California. The judge said that the sentence took into account the fact that Nikulin did not commit offences in the US territory. The defendant refused to speak in his defense. The prosecutors initially sought a sentence of 12 years. The defense insisted that there was no reason to keep Nikulin in custody for more than the period he had already spent behind bars (about four years). Nikulin had been accused of carrying out targeted attacks against the systems of US companies. He had been serving time in a Czech prison in Prague. In 2018, the Czech Republic extradited him to the United States. In early 2019, Nikulin was declared sane.

Wall Street Market

A coalition of law enforcement agencies led by the German Federal Criminal Police with the support of the UK National Crime Agency, Europol, Eurojust, and the FBI carried out an operation called Disruptor, which resulted in 179 arrests. All detainees are suspected of being involved in the sale of illegal goods and services, including drugs and firearms, on Wall Street Market, a large marketplace with over 1.1 million users and 5,400 sellers, which the police took down last year. The arrests took place in the United States (121), Germany (42), the Netherlands (8), the United Kingdom (4), Austria (3), and Sweden (1). Over $6.5 million were seized in both cash and virtual currencies, alongside some 500 kilograms of drugs, including oxycodone, methamphetamine, heroin, and cocaine, as well as 64 firearms.

Forecasts and warnings

- Threat actors may use data stolen with Loki PWS to gain access to email accounts and crypto wallets for the purposes of financial fraud, espionage, or sale of stolen data on hacker forums.

- JS sniffers are one of the most rapidly evolving threats to e-commerce at the moment. They have practically displaced banking Trojans. Since regular users can hardly determine whether an official online shop is infected with JS sniffers, we recommend using a virtual card with payment limits and link it to a separate bank account in order to minimize potential losses. Online businesses are advised to have regular small-scale audits of their websites as well as in-depth security assessments once per year. Still, website owners should regularly update CMS software for their websites.

- The lack of a strong communication channel between organizations that fight cybercrime coupled with the challenging political situation leads to the appearance of new criminal groups that feel safe. Another factor that makes it possible for cybercriminals to make money by demanding ransoms is businesses' underestimation of risks and a lack of security tools for promptly detecting and neutralizing ransomware.

- Social engineering techniques have been increasingly used in phone fraud during the pandemic. This activity will increase. Make sure not to reveal your payment card details to anyone over the phone; if there are any issues, it is best to call the financial organization yourself. Do not transfer money to any "safe" accounts and ensure that your critical information is stored in a place that cannot be accessed by third parties.

If you wish to receive more detailed information about a specific incident, threat, or criminal group:

Please contact us.

We can conduct investigations to give you the maximum intelligence on the threats targeting your organization.

+65 3159 3798
+7 495 984 33 64
intelligence@group-ib.com